

**ESCOLA
SUPERIOR
DE TECNOLOGIA
E GESTÃO**

P.PORTO

Criptografia Aplicada

Infraestruturas de Chave Pública (ICP / PKI)

Plano

ESCOLA SUPERIOR DE TECNOLOGIA E GESTÃO
POLITÉCNICO DO PORTO

Conceitos (rev.)

28/03/2025 GJH @ Criptografia Aplicada 2025.07 3

ESCOLA SUPERIOR DE TECNOLOGIA E GESTÃO
POLITÉCNICO DO PORTO

Certificados Digitais

- Certificados Digitais X.509
 - Standard de facto para os **certificados digitais**, inicialmente publicado em 1993
 - Atualmente na **versão 3 (v3)**
 - Estrutura
 - Definida no RFC 5280
 - Formato **ASN.1** (Abstract Syntax Notation One)¹⁾

```
certificado ::= SEQUENCE {
  version          INTEGER,
  serialNumber     INTEGER,
  signature        AlgorithmIdentifier,
  issuer           Name,
  validity         Validity,
  subject          Name,
  subjectPublicKey ECPublicKey,
  extensions       [0] IMPLICIT OCTET STRING OPTIONAL,
  ...
}

subject ::= SEQUENCE {
  cn                [1] IMPLICIT OCTET STRING OPTIONAL,
  ...
}
```

1) <https://www.svgadminis.hr/projects/asn1editor/default.aspx>

28/03/2025 GJH @ Criptografia Aplicada 2025.07 4

ESCOLA SUPERIOR DE TECNOLOGIA E GESTÃO
POLITÉCNICO DO PORTO

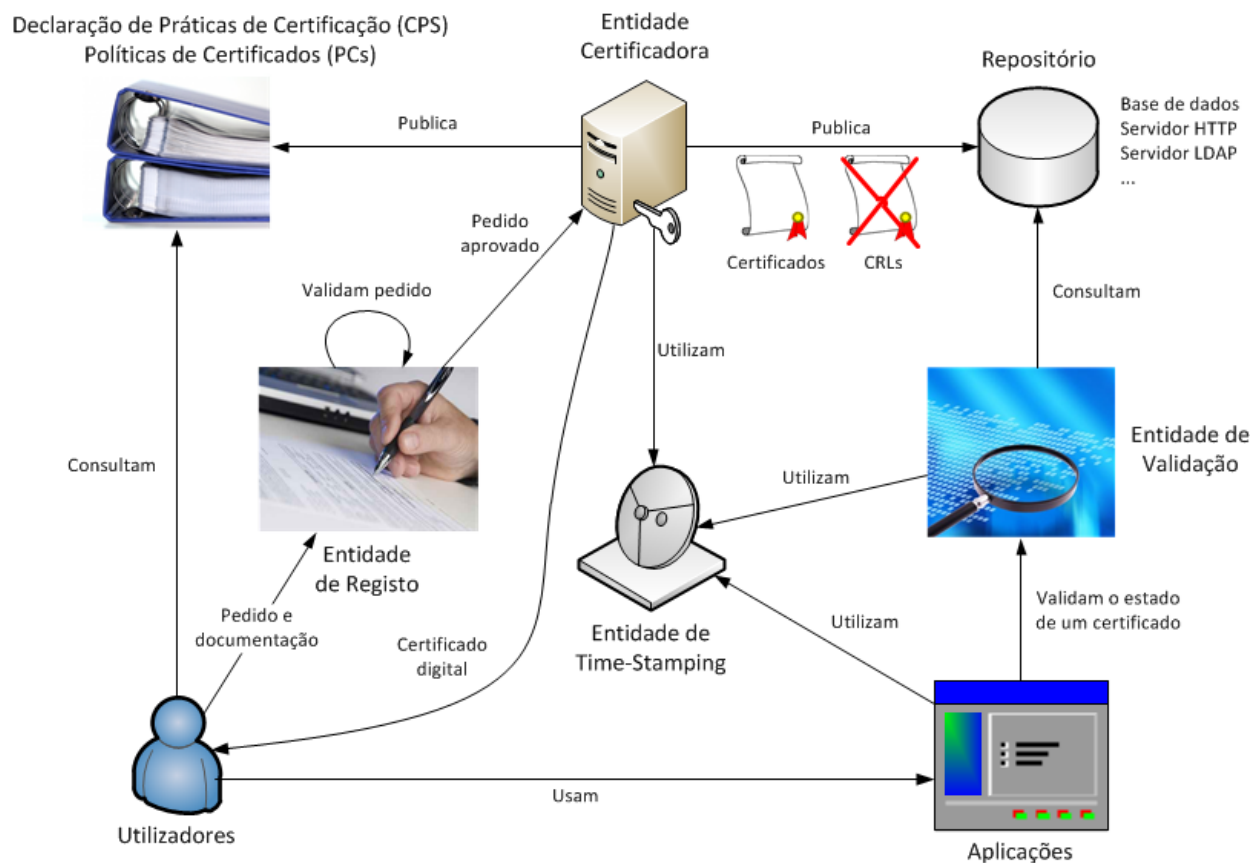
Enquadramento legal

- Jurídicos¹⁾
 - Assinatura Eletrónica
 - Resultado de um processamento eletrónico de dados suscetível de constituir objeto de direito individual e exclusivo e de ser utilizado para dar a conhecer a autoria de um documento eletrónico.
 - Assinatura Eletrónica Avançada
 - Assinatura eletrónica que preenche os seguintes requisitos:
 1. Identifica de forma **unívoca** o **titular** como **autor** do documento;
 2. A sua aposição ao documento depende **apenas** da vontade do titular;
 3. É criada com meios que o titular pode manter sob seu **controlo exclusivo**;
 4. A sua **conexão** com o documento permite detetar toda e qualquer alteração superveniente do conteúdo deste.

1) De acordo com os Decretos-Leis n.º 330-D/99 e 62/2003

28/03/2025 GJH @ Criptografia Aplicada 2025.07 18

Conceitos (rev.)



Certificados Digitais

- Certificados Digitais X.509
 - Standard de facto para os certificados digitais, inicialmente publicado em 1993
 - Atualmente na versão 3 (v3)
 - Estrutura
 - Definida no RFC 5280
 - Formato ASN.1 (Abstract Syntax Notation One)¹

```
Certificate ::= SEQUENCE {
    tbsCertificate      TBSCertificate,
    signatureAlgorithm  AlgorithmIdentifier,
    signatureValue      BIT STRING }

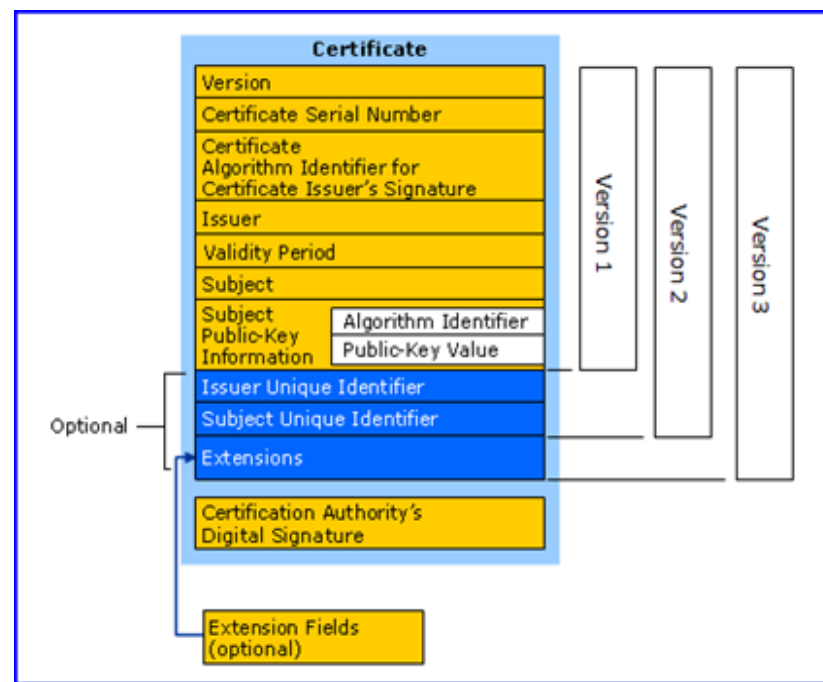
TBSCertificate ::= SEQUENCE {
    version             [0] EXPLICIT Version DEFAULT v1,
    serialNumber        CertificateSerialNumber,
    signature            AlgorithmIdentifier,
    issuer               Name,
    validity             Validity,
    subject              Name,
    subjectPublicKeyInfo SubjectPublicKeyInfo,
    issuerUniqueID       [1] IMPLICIT UniqueIdentifier OPTIONAL,
                        -- If present, version MUST be v2 or v3

    subjectUniqueID      [2] IMPLICIT UniqueIdentifier OPTIONAL,
                        -- If present, version MUST be v2 or v3
    extensions           [3] EXPLICIT Extensions OPTIONAL
                        -- If present, version MUST be v3
}
```

1) <https://www.sysadmins.lv/projects/asn1editor/default.aspx>

Certificados Digitais

- Certificados Digitais X.509
 - Conteúdo obrigatório
 - A versão da norma X.509 que cumpre (normalmente a v3)
 - Emissor (Issuer)
 - Identificado pelo seu DN (Distinguished Name)
 - Titular (Subject)
 - Também identificado pelo seu DN
 - Nº de série do certificado
 - Entidades certificadoras necessitam de assegurar a sua unicidade



Fonte: Microsoft

Certificados Digitais

- Certificados Digitais X.509
 - Conteúdo Obrigatório
 - Período de validade
 - Definido por uma data/hora de início e fim
 - Chave pública do titular
 - Identificador do algoritmo utilizado para assinar digitalmente o certificado
 - Assinatura digital
 - Efetuada pela entidade certificadora que o emitiu

Certificados Digitais

- Certificados Digitais X.509

- Conteúdo **Opcional**

- **Identificador único do emissor**

- Que permita **identificar univocamente** uma **entidade certificadora**, que poderá ter mais do que um certificado ao longo do tempo

- **Identificador único do titular**

- Por exemplo, o seu número de identificação civil

- **Extensões** - existem extensões previstas para incluir:

- o endereço de e-mail,
 - a localização da CRL,
 - CPS,
 - Política de certificados, etc
 - ...
 - Podem também ser incluídas **extensões proprietárias** ...

Certificados Digitais

- Certificados Digitais X.509

- DN ([Distinguished Names](#))

- Utilizados em certificados X.509 para [identificar o titular e a entidade certificadora](#)
 - Definidos na [norma X.500](#) no sentido de possibilitar a [identificação unívoca](#) de agentes/entidades em [serviços de diretoria](#)
 - Estão organizados [hierarquicamente](#) e são compostos [por RDN \(Relative Distinguished Name\)](#), que são pares [atributo/valor](#)
 - Os mais usuais são CN ([Common Name](#)), D ([Department](#)), OU ([Organizational Unit](#)), O ([Organization](#)) e C ([Country](#))
 - Exemplos:

CN = ESTG, OU=ESTG, O=IPP, C=PT

CN = Gonalo Hermenegildo, D=Informática, OU=ESTG, O=IPP, C=PT



Certificados Digitais

- Certificados Digitais X.509

- OID ([Object IDentifiers](#))

- Os [OID](#) são identificadores utilizados para [referenciar](#) objetos, conteúdos, conceitos ou “coisas” de forma inequívoca e persistente (standards, países, empresas, projetos, documentos, informação médica, dispositivos/rede, alertas climáticos)
 - Definidos pelo International Telecommunications Union (ITU) e International Organization for Standardization ISO/IEC na norma X.660
 - Utilizados em certificados X.509 para [identificar univocamente determinados tipos de objetos/conteúdos](#) (algoritmos, extensões, etc.)
 - Estão [organizados em nodos hierárquicos](#)
 - Cada OID é um nó da árvore de OIDs

Certificados Digitais

- Certificados Digitais X.509

- OID ([Object Identifiers](#))

- No sentido de assegurar que a sua utilização é uniformemente reconhecida por todos, [cada nodo deve ser registado/adquirido](#) a uma das entidades gestoras

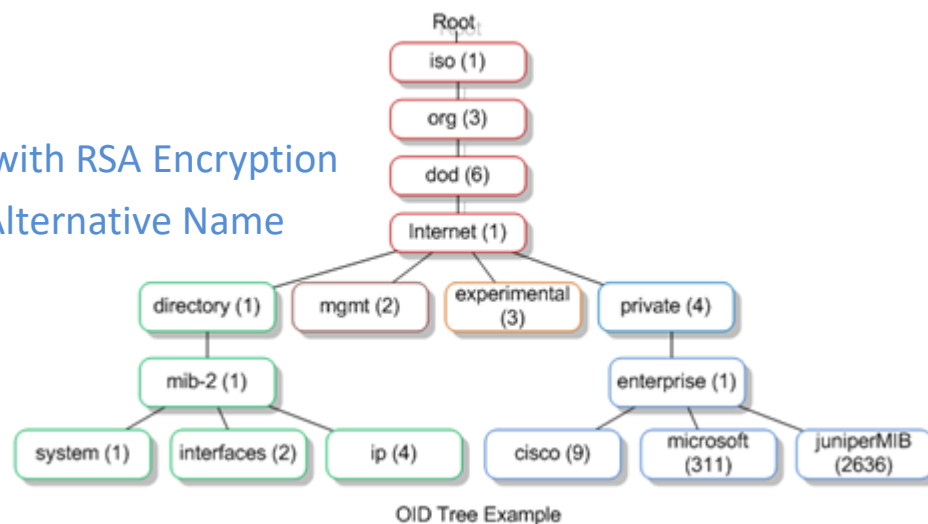
- IANA, HL7, etc.

- Exemplos:

- 1.2.840.113549.1.1.5 - [SHA-1 with RSA Encryption](#)

- 2.5.29.17 – [Extensão Subject Alternative Name](#)

- 1.3.6.1.4.1 - [IANA](#)



Certificados Digitais

- Certificados Digitais X.509
 - Formato DER (Distinguished Encoding Rules)
 - Sintaxe de transferência de mensagens definida pela ITU (International Telecommunication Union) na norma X.690
 - Utilizado para codificar um certificado X.509 em binário, pelo que não pode ser impresso ou enviado por e-mail sem conversão
 - Também utilizado para codificar outros tipos de objetos (CRLs, assinaturas digitais, etc.)
 - Formato PEM (Privacy Enhanced Mail)
 - Definido como parte de uma proposta da IETF para a utilização segura de e-mail
 - Utilizado para codificar um certificado X.509 em formato textual (Base64), facilmente passível de impressão ou envio por e-mail

Certificados Digitais

- Certificados Digitais X.509

- Formato **PEM** (Privacy Enhanced Mail)

-----BEGIN CERTIFICATE-----

MI IHGjCCBQKqAwIBAGiIV/NnOxBu03kwdQYJKoZlHvcNAQEFBQAwYQXCzAJBgNV
BAYTA1BUMAUwPgyDVQZQKDDdtQOVFIC0gU2lzdGVtYSBkZSBZDZXJ0aWZpY2HdpS0j
byBfBGVjdHdLDS25pY2EgZG8gRXN0YWRvMREwDwyDVQQLDAhFQ0VzdGFkbzEgMB4G
A1UEAwwXQ2FydMOjbyBkZSBDAWRhZMOjbyAwMDIwHhcNMTMwNTIwMTcyODAYWWhcN
MTkwNzIwMTczODAYWjCBjDELMAKGA1UEBhMCUFQxHDAaBgNVBAoME0NhcncTDo28g
ZGUgQ2lkyWTD028xFDASBgNVBASMC3N1YkVDRXN0YWRvMUKwRwYDVQZDDEBfQyBk
ZSBBC3NpbmF0dXJhIERPZ2l0YWwGU2l0YWRvMUKwRwYDVQZDDEBfQyBkZSBZ
aWRhZMOjbyAwMDA4MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEazI6+
uYvJepLdSIWskTgUb470dA4IuUYEffoduxTOot3G9luptcYX73s+R8+B7whwxvn
wFAuVkkHfCvsvXqkLyeWYq3Ye+fJM8E+GnnbolnNnx4gmc/DlvtvT6JbQHM1s3iCkI
rYXe2xAtzFyF7BIWL7wfa1/kZeTVLazHbSMMHIFujOJ/xFqCnASGq2tyW/HZ6w7
FkYymzvOfJEiAAuDn/6Dn55aqr15HHNGONxzy7rgdN19C707Fnnl1lekUivOU06+u
KoVhPhDoT3vKfj58cirJNRDGHZ+fxsnOy1064ZrYFYnZDXZkjtLuLc2iPuUJfE2d
gJyaZ2V+A386KJhWVWIDAQABO4IChDCCAOAwEgYDVR0TAQH/BAgwBgEB/wIBADAQ
BgNVHQ8BAf8EBAMCAQYwHQYDVR0OBBYEFD+HQHdG+Ub3o170bxbw4A0gK3rjMB8G
A1UdIwQYMBAAFLPvRiwrDC8wMkyL8PTcgDIakQVMIIBCQYDVR0gBIIiBADAQAw
MgYEVR0gADAgMCgGCCsGAQUFBwIBFhxodHRwOi8vd3d3LnNjZWUuZ292LnB0L3Bj
ZXJ0MIHfBgtgthGwBAQECAABAjCBtTCBsgYIKwYBBQUHAgIwgaUegaIAAAB0AHQA
cAA6AC8ALwBwAGsAAQAuAGMAYQBYAHQAYQBVAGQAZQBjAGkAZABhAGQAYQBVAC4A
cAB0AC8AcAB1AGIAbABpAGMAbwAvAHAAbwBsAGkAdABpAGMAYQBYAC8AcABjAC8A

YwBjAF8AcwB1AGIALQB1AGMAXwBjAGkAZABhAGQAYQBvAF8AYQBzAHMAcQBfAHAA
YwAuAGgAdABtAGwwZgYKYIRsAQEBAGQABzBYMFYGCCsGAQUFBwIBFkpodHRwOi8v
cGtpLmNhc nRhb2RlY2lkYW Rhby5wdC9wdWJsaWNvL3BvbGl0aWNhcy9kcmV y2Nf
ZW NfY2lkYW Rhb19kcGMuahrBtDBXBgNVHR8EUDBOMEygsQB1hkZodHRwOi8vcGtp
LmNhc nRhb2RlY2lkYW Rhby5wdC9wdWJsaWNvL2xyYy9jY19lY19jaWRhZGFvX2Ny
bDAwMl9jcmw uY3JsMEwGCCsGAQUFBwEBBEAwPjA8BggrBgEFBQcwAYYwaHR0cDov
L29j c3Aucm9vdC5jYXJ0Yw9kZW NpZG FkYw8ucH QvcH VibiG1jby9vY3NwMA0GCSqG
S1b3DQEBBQUAA4ICAQByHxfZ5Xuo4613n2quUUrXrchgr4ARESOAdd1Kbn3bTpQF
1nxQVaT2R/j+ttA3dmqQTKt2zzM7CrG366vB3L+P8mqyngBbQj1wFerL3QiiPjBkS
gRtntNtFPQdo9B1kKpovjHNAJw+asS/tP1kxUaHPNmmqBXIw3kpG+ffp+APgRusUP
HGNg9gFyq9Ca5tcqGXHF+Y7WGA btr5Ij6kJ1F+Zobs6+HeJzB/cU0bV9+c2T+Xpb
+U7paz8J+fj4XAWTKV2tFigkYatMyhG+kBtdHeOOkdHHOEF7y8ikB+tgKd+48Yab
yJKn1Ub5hiDaTtI/xm0zL9PyLwo2P5eMGefPPTGdBXdG3iC1b+IrgXTewvUHL Lru
+ZZiy2a4gTdyWQ1TeglpOwQ1Eqpcp7rKwSMLY6Vid0Pay60GiJ6hqpPq6rNxBmMN
jijNeLb4fgYUYHMDKCc0XfRDI3pDarV3XiUchj/YPNAMygvJzvuhKfsvGVGN0vtI
VlsgxuAmZVDyfxWnJSPA5eXA4u687VQnETiJpV5cBoSgNXy8ZVjXRX0bkSrNbYUn
AH6MCKEbyjPgHcx0RC3ta6rPfrcaKFEEzoIUFWj bV0ca4apMvWiIwoOj88UwZDY
yglXvRcsGNBdf9iILbYukKaAlala/R8ZmL6zoPIwDoo4DmeLkaFZ4j7i+cyA==
-----END CERTIFICATE-----

Certificados Digitais

- Certificados Digitais X.509
 - Utilização da Chave / Key Usage

Bit	Designação	Significado
0	digitalSignature	A chave pública do titular pode ser utilizada para verificar assinaturas digitais de dados que não sejam certificados digitais (ver bit 5) ou CRLs (ver bit 6). Contudo, as mesmas apenas vinculam o titular se o bit 1 for usado ou se a respetiva política de certificados o estipular
1	nonRepudiation ⁽¹⁾	O titular não pode negar ser o autor/origem dos dados assinados
2	keyEncipherment	Quando a chave pública pode ser usada por terceiros para lhe enviarem chaves secretas/privadas de forma cifrada
3	dataEncipherment	Quando a chave pública pode ser usada por terceiros para lhe enviarem dados (que não chaves secretas/privadas) de forma cifrada

Certificados Digitais

- Certificados Digitais X.509

- Utilização da Chave / Key Usage

Bit	Designação	Significado
4	keyAgreement	A chave pública pode ser usada por terceiros para efetuar um acordo de chaves com o titular (por exemplo, para criar um canal de comunicação cifrado entre ambos)
5	keyCertSign	A chave pública pode ser utilizada para verificar assinaturas de certificados digitais (ou seja, titular pode emitir certificados digitais)
6	cRLSign	A chave pública pode ser utilizada para verificar assinaturas de CRLs (ou seja, titular pode emitir CRLs)
7	encipherOnly	Caso o bit 4 seja 1, a chave pública apenas pode ser utilizada para cifrar dados durante um processo de acordo de chaves (caso contrário, é ignorado)
8	decipherOnly	Caso o bit 4 seja 1, a chave pública apenas pode ser utilizada para decifrar dados durante um processo de acordo de chaves (caso contrário, é ignorado)

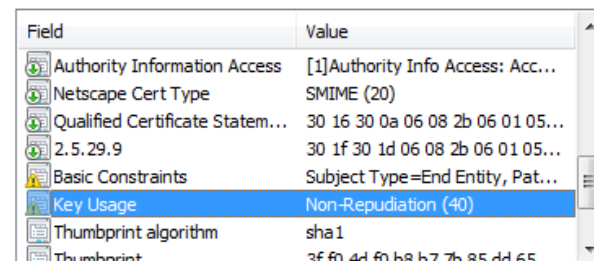
Certificados Digitais

- Certificados Digitais X.509

- Utilização da Chave / Key Usage
- Exemplo: Cartão de Cidadão

- Certificado de Assinatura

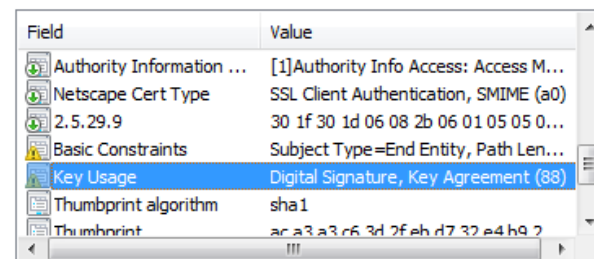
- Key Usage = nonRepudiation
 - Cidadão pode utilizá-lo (por exemplo) para assinar documentos ou e-mail, não podendo posteriormente negar que o fez



Field	Value
Authority Information Access	[1]Authority Info Access: Acc...
Netscape Cert Type	SMIME (20)
Qualified Certificate Statem...	30 16 30 0a 06 08 2b 06 01 05...
2.5.29.9	30 1f 30 1d 06 08 2b 06 01 05...
Basic Constraints	Subject Type=End Entity, Pat...
Key Usage	Non-Repudiation (40)
Thumbprint algorithm	sha1
Thumbprint	3f f0 4d f0 b8 b7 7b 85 dd 65

- Certificado de Autenticação

- Key Usage = digitalSignature, keyAgreement
 - Cidadão pode utilizá-lo em mecanismos de desafio/resposta ou para criar canais de comunicação seguros com terceiros (por exemplo, via SSL)



Field	Value
Authority Information ...	[1]Authority Info Access: Access M...
Netscape Cert Type	SSL Client Authentication, SMIME (a0)
2.5.29.9	30 1f 30 1d 06 08 2b 06 01 05 05 0...
Basic Constraints	Subject Type=End Entity, Path Len...
Key Usage	Digital Signature, Key Agreement (88)
Thumbprint algorithm	sha1
Thumbprint	ac a3 a3 c6 3d 2f eb d7 32 e4 b9 2

Certificados Digitais

- Estados de um certificado

Ativo

Expirado

Revogado

Suspenso

Certificados Digitais

- Ciclo de vida



Enquadramento legal

- Jurídicos¹

- Assinatura Eletrónica

- Resultado de um **processamento eletrónico de dados** suscetível de **constituir objeto de direito individual e exclusivo** e de ser **utilizado para dar a conhecer a autoria de um documento eletrónico**.

- Assinatura Eletrónica Avançada

- Assinatura eletrónica que preenche os seguintes **requisitos**:
 1. **Identifica** de forma **unívoca** o **titular** como **autor do documento**;
 2. A sua **aposição** ao documento depende **apenas** da **vontade do titular**;
 3. É criada com meios que o titular pode manter sob seu **controlo exclusivo**;
 4. A sua **conexão** com o **documento** permite **detetar toda e qualquer alteração** superveniente do **conteúdo deste**.

1) De acordo com os **Decretos-Lei n.º 290-D/99 e 62/2003**

Enquadramento legal

- Jurídicos

- Assinatura Digital

- Modalidade de assinatura eletrónica avançada baseada em sistema criptográfico assimétrico composto de um algoritmo ou série de algoritmos, mediante o qual é gerado um par de chaves assimétricas exclusivas e interdependentes, uma das quais privada e outra pública, e que permite ao titular utilizar a chave privada para declarar a autoria do documento eletrónico ao qual a assinatura é aposta e concordância com o seu conteúdo e ao destinatário utilizar a chave pública para verificar se a assinatura foi criada mediante o uso da correspondente chave privada e se o documento eletrónico foi alterado depois de aposta a assinatura.

- Dispositivo de Criação de Assinatura

- Suporte lógico ou dispositivo de equipamento utilizado para possibilitar o tratamento dos dados de criação de assinatura.

Enquadramento legal

- Jurídicos

- Dispositivo Seguro de Criação de Assinatura

- Dispositivo de criação de assinatura que assegure, através de meios técnicos e processuais adequados, que:

Chave Privada

1. Os dados necessários à criação de uma assinatura só possam ocorrer uma única vez e que a confidencialidade desses dados se encontre assegurada;
2. Os dados necessários à criação de uma assinatura utilizados na geração de uma assinatura não possam, com um grau razoável de segurança, ser deduzidos de outros dados e que a assinatura esteja protegida contra falsificações realizadas através das tecnologias disponíveis;
3. Os dados necessários à criação de uma assinatura utilizados na geração de uma assinatura possam ser eficazmente protegidos pelo titular contra a utilização ilegítima por terceiros;
4. Os dados que careçam de assinatura não sejam modificados e possam ser apresentados ao titular antes do processo de assinatura.

Às vezes difícil/inútil dado que o utilizador nem sempre assina algo que consiga interpretar (exemplo, XML)

Entidade Certificadora não pode permitir repetição de pares de chaves

A combinação destes requisitos implica a utilização de um dispositivo físico (smartcard, token USB, etc.) e a sua entrega em mão ao titular

Enquadramento legal

- Jurídicos

- Assinatura Eletrónica Qualificada

- Assinatura digital ou outra modalidade de assinatura eletrónica avançada que satisfaça exigências de segurança idênticas às da assinatura digital baseadas num certificado qualificado e criadas através de um dispositivo seguro de criação de assinatura.
- A aposição de uma assinatura eletrónica qualificada a um documento eletrónico equivale à assinatura autografa dos documentos com forma escrita sobre suporte de papel e cria a presunção de que:
 - A pessoa que apôs a assinatura eletrónica qualificada é o titular desta ou é representante, com poderes bastantes, da pessoa coletiva titular da assinatura eletrónica qualificada;
 - A assinatura eletrónica qualificada foi aposta com a intenção de assinar o documento eletrónico;
 - O documento eletrónico não sofreu alteração desde que lhe foi aposta a assinatura eletrónica qualificada.
- A aposição de assinatura eletrónica qualificada substitui, para todos os efeitos legais, a aposição de selos, carimbos, marcas ou outros sinais identificadores do seu titular.

Enquadramento legal

- Jurídicos

- Certificado Qualificado

- Certificado que contém os elementos referidos no artigo 29.º¹ e é emitido por entidade certificadora que reúne os requisitos definidos no artigo 24.º¹.
 - Entre outras coisas, artigo 24.º determina que as entidades certificadoras que emitem este tipo de certificados necessitam de:
 - Ter requisitos patrimoniais mínimos
 - Manter um contrato de seguro válido para a cobertura adequada da responsabilidade civil emergente da atividade
 - Verificar rigorosamente a identidade dos requerentes titulares dos certificados e representantes de pessoas coletivas
 - Conservar os certificados durante (pelo menos) 20 anos

1) De acordo com os Decretos-Lei n.º [290-D/99](#), [62/2003](#) e [12/2021](#)

Enquadramento legal

- Jurídicos

- Certificado Qualificado (cont.)

- Artigo 9.º determina que:
 - É livre o exercício da atividade de entidade certificadora, sendo facultativa a solicitação da credenciação regulada nos artigos 11.o e seguintes.
 - Sem prejuízo do disposto no número anterior, as entidades certificadoras que emitam certificados qualificados devem proceder ao seu registo junto da autoridade credenciadora, nos termos a fixar por portaria do Ministro da Justiça.
 - Mesmo que uma entidade certificadora apenas se registe, tem que garantir que emite certificados qualificados e sujeitar-se a auditorias
 - Apesar de credenciação ser facultativa, a sua obtenção é vista como uma questão de prestígio

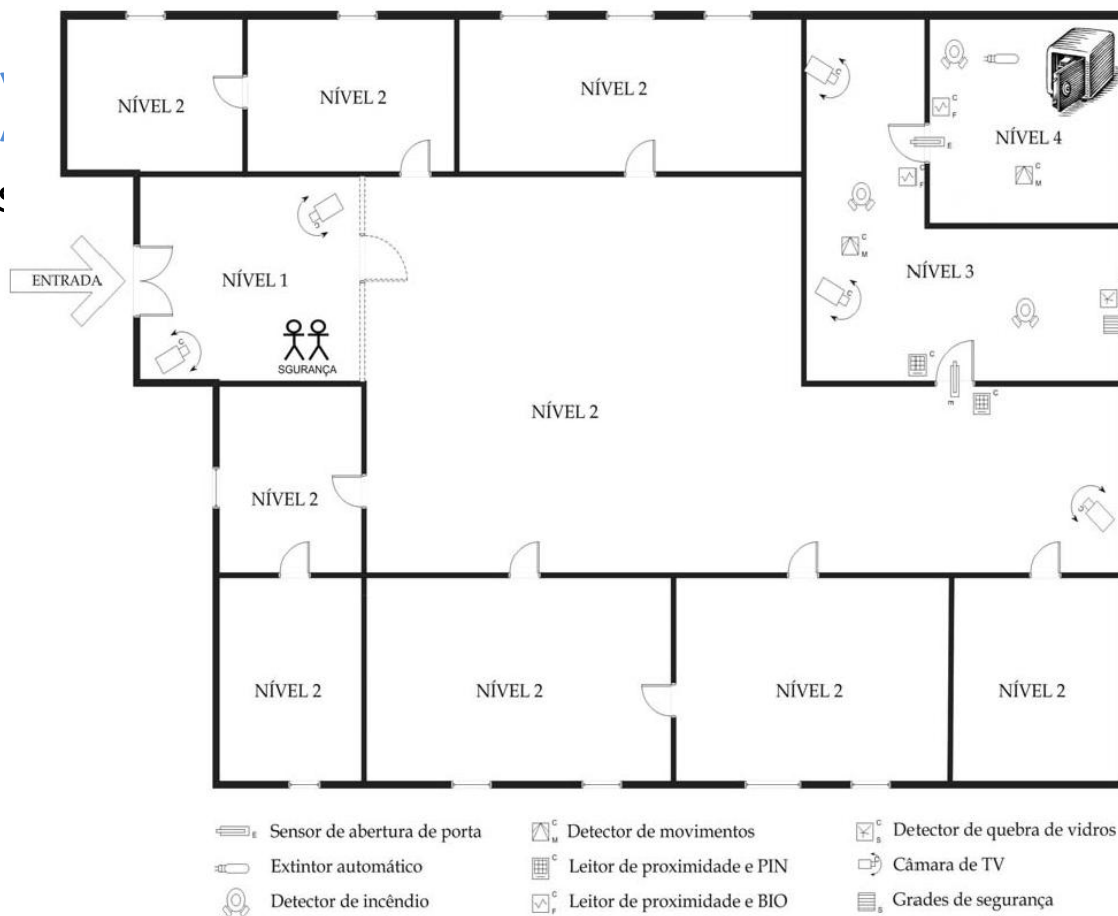
Enquadramento legal

- Credenciação

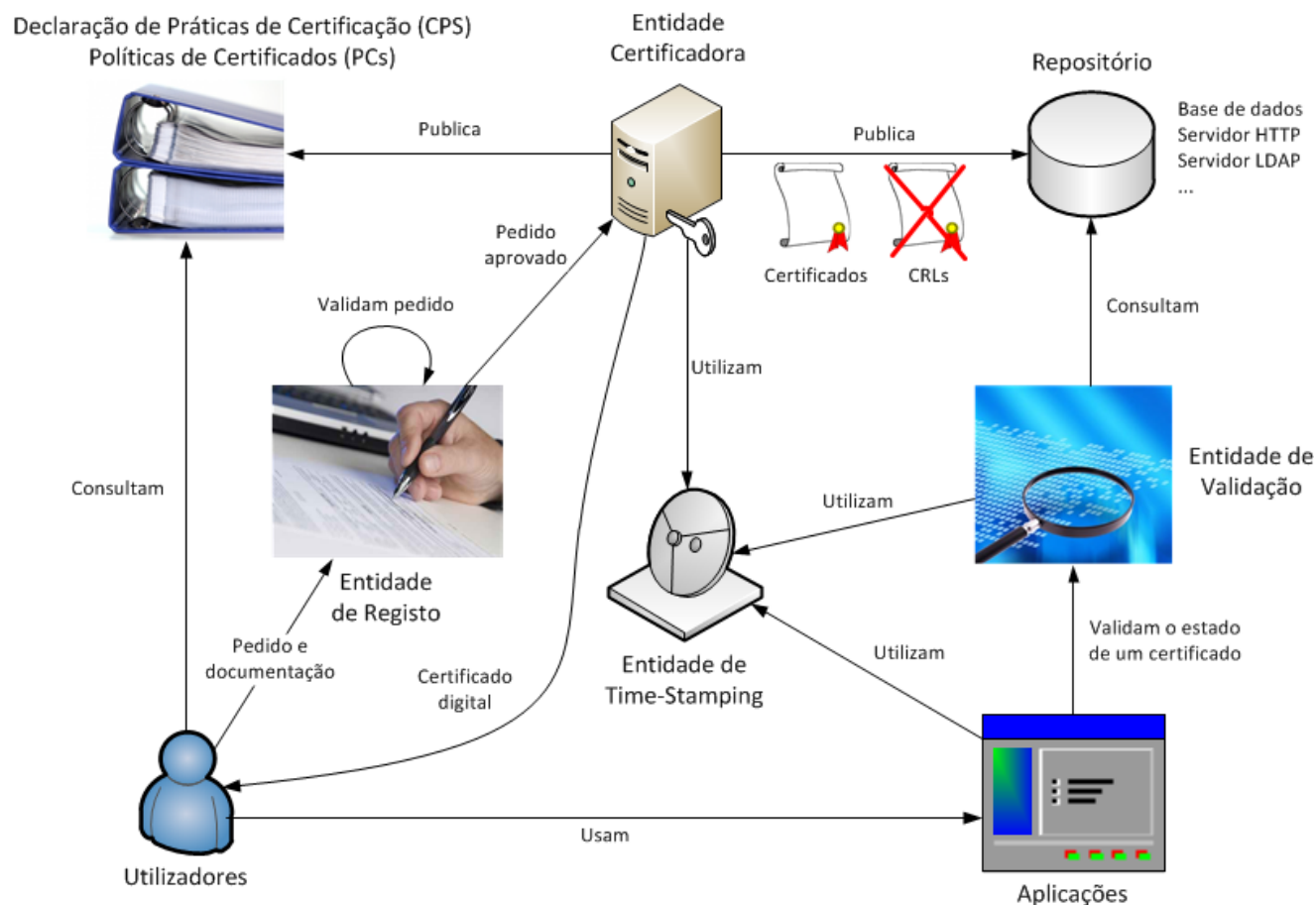
- Gerida pelo [Gabinete Nacional de Segurança](#), obriga à realização de auditorias periódicas por auditores reconhecidos
- Implica a [observância um conjunto de normas e legislação](#) sobre:
 - Segurança de [processos](#)
 - Segurança [ambiental](#)
 - Segurança de [recursos humanos](#) e [segregação de funções](#)
 - Segurança e [fiabilidade](#) de [software e hardware](#) utilizado
 - Plano de [continuidade](#) de negócio (PCN)
 - Gestão de [risco](#)
 - Segurança das [instalações físicas](#)
 - ...

Enquadramento legal

- Credenciação (cont.)
 - Segurança das instalações Físicas



Questões?



ICP/PKI – Prática Laboratorial

- Certificados Digitais multiplataforma (OS)
 - Teste as seguintes aplicações alternativas para utilização de Certificados Digitais
 - KeyStore Explorer
 - <https://keystore-explorer.org/>
 - XCA
 - <https://www.hohnstaedt.de/xca/index.php>
 - Emita um CSR (certificate request) com openssl e assine-o digitalmente com uma AC/EC criada com uma das aplicações anteriores
 - Software alternativo para emissão de certificados digitais:
 - Easy-CA
 - SmallStep CA (Step-CA)
 - EJBCA
 - Microsoft ADCS
 - Dogtag
 - Hashicorp Vault
 - OpenXPKI